

Sterclicks — Privacidad, consentimiento y backups

Documento de contexto completo para Claude Code

Este documento resume dos módulos desarrollados para el proyecto Sterclicks (CodeIgniter 4, hosting Hostinger): (1) un sistema de solicitud de consentimiento de marketing a usuarios ya registrados, y (2) un sistema de backups cifrados de la base de datos administrable desde el panel de administración. Incluye el razonamiento legal detrás de las decisiones, los archivos ya generados y qué falta por integrar en el proyecto real.

Parte 1 — Consentimiento de marketing

1.1 Contexto y problema legal

Sterclicks tiene ~500 usuarios registrados que solo se dieron de alta para acceder al panel de usuario y personalización de figuras. Nunca dieron consentimiento para recibir publicidad. Bajo RGPD/LOPDGDD, la base legal del registro fue "ejecución del contrato/prestación del servicio", que no cubre el envío de marketing: eso requiere una base legal distinta, normalmente consentimiento explícito.

La LSSI-CE (art. 21.2) permite el llamado "soft opt-in": enviar publicidad de productos propios similares sin consentimiento previo si ya hubo relación contractual (compra), se informó en su momento del uso comercial de los datos, y se ofrece opt-out fácil en cada envío. Como los usuarios de Sterclicks solo se registraron (sin necesariamente comprar, y sin ese aviso previo), esta excepción no aplica con seguridad — de ahí la decisión de pedir opt-in explícito.

1.2 Estrategia acordada

- Enviar un único email de solicitud de consentimiento, con tono sobrio (no promocional), a los 500 usuarios. Al no ser publicidad en sí mismo, se puede enviar sin tener aún el consentimiento.
- Cada usuario recibe un enlace único y personalizado (token de un solo uso) para confirmar con un clic.
- Silencio = no consentimiento. Nunca al revés (nada de opt-out implícito ni checkboxes premarcados).
- Toda confirmación/baja queda registrada con fecha, IP y user agent como evidencia ante una posible inspección de la AEPD.

1.3 Proveedor de envío: Brevo

Se eligió Brevo (antes Sendinblue) sobre Mailrelay, Amazon SES y SMTP propio de Hostinger: plan gratuito de 300 emails/día (suficiente para 500 usuarios en un par de días), servidores en la UE, cumplimiento RGPD nativo, y gestión de opt-out ya integrada para cuando se envíen campañas reales.

1.4 Cambios en base de datos

Archivo: `app/Database/Migrations/2026-08-13-000001_AddMarketingConsent.php`

- `pers.marketing_consent` — TINYINT(1), default 0
- `pers.marketing_consent_at` — DATETIME, nullable
- `pers.consent_token` — VARCHAR(64), nullable, token de un solo uso

Tabla nueva marketing_consent_log (id, user_id, action ENUM granted/revoked, ip_address, user_agent, created_at) — log inmutable independiente del flag actual, es la prueba documental del consentimiento.

1.5 Controlador de consentimiento

Archivo: app/Controllers/ConsentController.php

confirm() — GET /confirmar-newsletter?token=XXXX. Busca por consent_token, marca marketing_consent=1, guarda fecha, invalida el token e inserta log 'granted'.

revoke() — GET /baja-newsletter, requiere usuario autenticado. Marca marketing_consent=0 e inserta log 'revoked'. Ajustar auth()->id() al sistema real de autenticación de Sterclicks.

Rutas a añadir en app/Config/Routes.php:

```
$routes->get('confirmar-newsletter', 'ConsentController::confirm');
$routes->get('baja-newsletter', 'ConsentController::revoke');
```

1.6 Comando de envío masivo

Archivo: app/Commands/SendConsentEmails.php. Recorre usuarios con marketing_consent=0, genera un token de 32 bytes por usuario, y envía un email individual y personalizado vía la API transaccional de Brevo (api.brevo.com/v3/smtp/email). Requiere BREVO_API_KEY en .env.

```
php spark consent:send --dry-run --limit=5 # prueba en seco
php spark consent:send --limit=5          # envío real de prueba
php spark consent:send                     # envío a todos los pendientes
```

1.7 Pendiente de integrar

Confirmar que UserModel incluye 'consent_token' y 'marketing_consent' en \$allowedFields.

Ajustar auth()->id() en ConsentController::revoke() al sistema real de autenticación.

Crear cuenta Brevo, generar API key, añadirla como BREVO_API_KEY en .env.

Verificar dominio (SPF/DKIM) en Brevo desde el DNS de Hostinger.

Crear la vista consent_confirmed (página de agradecimiento tras confirmar).

Añadir checkbox de marketing (no premarcado) al formulario de registro futuro y actualizar la política de privacidad.

Probar con --dry-run y después --limit=5 antes del envío a los 500.

Parte 2 — Sistema de backups cifrados

2.1 Contexto y marco legal

Objetivo: automatizar backups de la base de datos de Sterclicks cumpliendo RGPD/LOPDGDD (la LOPD de 1999 ya no está vigente). El backup en sí no requiere una base legal nueva — es una medida de seguridad exigida por el art. 32 RGPD — pero hereda las mismas obligaciones de protección que los datos originales.

&bun Almacenamiento dentro del EEE (Espacio Económico Europeo) o con garantías equivalentes (SCCs / Data Privacy Framework) si es fuera.

&bun Cifrado en reposo del propio archivo de backup, no solo del canal de transmisión.

&bun Cifrado en tránsito (SFTP/HTTPS, nunca FTP plano).

&bun Control de acceso restringido (solo admins, credenciales propias).

&bun Retención limitada con borrado automático (principio de minimización).

&bun Reflejar esta actividad en el Registro de Actividades de Tratamiento (RAT).

&bun Contrato de encargado de tratamiento (DPA, art. 28 RGPD) firmado con el proveedor de almacenamiento.

&bun Notificación a la AEPD en 72h ante incidente de seguridad con riesgo para los usuarios (art. 33 RGPD).

2.2 Proveedor de almacenamiento: Backblaze B2 (región UE)

Elegido por precio, API compatible con S3, y disponibilidad de región europea (ej. eu-central-003). Alternativa válida: Wasabi EU o un segundo VPS en la UE.

2.3 Arquitectura implementada

&bun BackupService (app/Libraries/BackupService.php) — hace mysqldump, cifra con OpenSSL AES-256-CBC (clave derivada por SHA-256, IV aleatorio por archivo), sube a B2 vía AWS SDK (API S3-compatible), calcula checksum SHA-256, y aplica retención automática borrando backups caducados tanto en B2 como en el log local.

&bun RunBackup (app/Commands/RunBackup.php) — comando Spark disparado por el cron de Hostinger (hPanel > Avanzado > Cron Jobs), pensado para ejecución diaria.

&bun BackupController (app/Controllers/BackupController.php) — panel de admin: listar historial, lanzar backup manual, descargar (descifrado puntual) y borrar. Debe protegerse con un filtro de admin en las rutas.

&bun BackupModel (app/Models/BackupModel.php) — log de cada backup: filename, tamaño, checksum, ruta en B2, estado (pending/ok/failed), quién lo disparó (cron/manual) y cuándo.

&bun Vista admin/backups/index.php — tabla con historial, botón "Hacer backup ahora", enlaces de descarga y borrado con confirmación.

&bun Migración 2026-08-13-000002_AddBackupsTable.php — crea la tabla backups.

2.4 Variables de entorno necesarias (.env)

```
backup.encryptedKey = (openssl rand -base64 32, guardar aparte)
backup.b2KeyId      =
backup.b2AppKey      =
backup.b2Bucket      = sterclicks-backups
backup.b2Endpoint    = s3.eu-central-003.backblazeb2.com
backup.retentionDays = 30
```

La clave de cifrado NUNCA debe guardarse en el mismo servidor que los backups ni subirse a Git — guardarla en un gestor de contraseñas aparte. Si se pierde, los backups antiguos quedan irrecuperables.

2.5 Comando de cron sugerido en Hostinger

```
/usr/bin/php /home/USUARIO/domains/sterclicks.com/public_html/spark backup:run  
Frecuencia sugerida: diaria, 04:00
```

2.6 Rutas de administración (proteger con filtro admin)

```
$routes->group('admin/backups', ['filter' => 'adminOnly'], function ($routes) {  
    $routes->get('/', 'BackupController::index');  
    $routes->post('run', 'BackupController::run');  
    $routes->get('download/(:num)', 'BackupController::download/$1');  
    $routes->delete('/:num)', 'BackupController::destroy/$1');  
});
```

2.7 Pendiente de integrar

- • composer require aws/aws-sdk-php (necesario para hablar con B2 vía API S3-compatible).
- • Crear cuenta y bucket privado en Backblaze B2, región UE, con App Key limitada a ese bucket (no la master key).
- • Generar y guardar la clave de cifrado fuera del servidor.
- • Rellenar el .env con las credenciales reales.
- • php spark migrate.
- • Añadir el filtro adminOnly en app/Config/Filters.php y aplicarlo a las rutas de backups.
- • Configurar el cron job en hPanel.
- • Firmar el DPA de Backblaze (descargable desde su panel, sección legal/compliance).
- • Añadir esta actividad de tratamiento (backups) al Registro de Actividades de Tratamiento (RAT) de Sterclicks.

Nota legal: este documento resume decisiones tomadas en conversación con Claude (chat), no sustituye asesoramiento de un abogado especializado en protección de datos ni de un DPO.